

Plan de continuité & de reprise d'activité

Comment l'activité commerciale continue pendant un incident (piratage, panne, perte d'un prestataire), et comment le Hub revient en service — dans quel ordre, en combien de temps, avec quelle perte de données maximale. À relire tous les 6 mois et après chaque changement d'hébergeur. Source : PCA_PRA.md (dépôt deb02CRM).

1 · Périmètre et actifs

Actif	Où	Rôle	Source de vérité
Front statique (HTML + dist/)	Vercel (cible : OVH)	Interface du CRM	Dépôt GitHub
Fonctions API (pappers-proxy, send-email, find-email, calendar-event, 3cx-webhook)	Vercel (cible : Edge Functions Supabase)	Proxys authentifiés, secrets côté serveur	Dépôt GitHub
Postgres, Auth, Storage, Edge Function inbound-mail	Supabase	Toutes les données métier	Base en service + dumps
Schéma SQL + migrations	sql/ du dépôt	Reconstruction à neuf	Dépôt GitHub
Domaine + DNS	Registrar	Accès utilisateurs	Compte registrar
Secrets (Pappers, SMTP, clés Supabase)	Env. hébergeur / secrets Supabase	Accès aux services tiers	Registre des secrets (§6.2)

La donnée qui ne se remplace pas est dans Supabase. Le front et les fonctions se redéploient à l'identique depuis GitHub en moins d'une heure ; un client, un devis ou une facture perdus ne se redéploient pas.

2 · Objectifs

Indicateur	Cible	Comment elle est tenue
RPO — perte de données max	24 h max	Dump quotidien chiffré et externalisé (§6.1) + backups Supabase
RTO front — retour de l'interface	1 h max	Redéploiement statique depuis GitHub, n'importe quel hébergeur
RTO complet — base restaurée, API opérationnelles	4 h ouvrées max	Procédure DEPLOIEMENT.md + restauration dump
Notification CNIL si données personnelles compromises	72 h max	§5, étape « Notifier » — le CRM contient des données personnelles, l'obligation RGPD s'applique

3 · PCA — continuer à travailler pendant l'incident

3.1 · Modes dégradés, du moins grave au plus grave

- Front indisponible, Supabase intact** (défacement, panne hébergeur) : basculer le DNS vers un second hébergeur statique où le dépôt est déployé — le front est portable par conception. En attendant : page de maintenance statique.
- Fonctions API indisponibles** (Pappers, envoi d'email) : le CRM reste utilisable — consultation, saisie, opportunités. Envoyer les emails depuis la messagerie normale, en notant l'action dans la fiche.
- Supabase indisponible ou suspect** : le Hub est hors service. Procédure manuelle : modèles de devis/contrats du dépôt + téléphone. Consigner tout sur un document partagé (main courante) pour ressaisie après reprise.

3.2 · Rôles et décision

Qui	Fonction	Rôle en incident
Dorian	Chef d'orchestre	Décideur incident : déclenche le PCA/PRA, décide de couper, coordonne, tient la chronologie
Guillaume	Développeur, administrateur 1er niveau des outils	Opérateur technique : exécute le PRA (révocations, restauration, redéploiements), contacte les supports Supabase / hébergeur
Romain	Relation client	Communication clients : informe les clients, consigne leurs demandes en mode manuel (§3.1.3), prépare l'information des personnes concernées si données exposées
Laurent	Directeur technique	Supervision technique : valide les actions techniques lourdes (coupure, restauration, rotation des clés), appuie Guillaume, point de contact des prestataires techniques, suppléant du décideur

Rôle	Titulaire	Suppléant
Décideur incident (déclenche PCA/PRA, décide de couper)	Dorian	Laurent
Opérateur technique (exécute le PRA)	Guillaume	Laurent
Communication clients / équipe	Romain	Dorian

Règle simple : au moindre soupçon de compromission de la base, on coupe d'abord, on analyse ensuite. Mettre le site en maintenance et suspendre les clés coûte une heure ; une fuite de données clients coûte beaucoup plus.

3.3 · Communication

- Équipe : canal interne habituel + point à heure fixe tant que l'incident dure.
- Clients : ne communiquer que des faits établis ; si des données personnelles sont concernées, information des personnes + notification CNIL sous 72 h. Le standard suit la fiche imprimée (Fiche_standard_incident.pdf, §6.4).
- Ne **jamais** communiquer les détails techniques de la faille avant correction.

4 · Prévention — les 5 points qui conditionnent le plan

La checklist complète est dans SECURITE_RESEAU.md (dépôt deb02local). L'essentiel :

1. **MFA obligatoire** sur Supabase, GitHub, Vercel/OVH, registrar, messagerie.
2. **Dump quotidien chiffré externalisé** (§6.1) — sans lui, le RPO de 24 h est fictif.
3. **Branch protection sur main** (revue obligatoire) — les migrations SQL du dépôt sont un chemin d'exécution vers la prod.
4. **Registre des secrets à jour** (§6.2) — en incident, on ne cherche pas, on révoque.
5. **Test de restauration trimestriel** (§7) — un backup jamais restauré n'est pas un backup.

5 · PRA — reprise après piratage, par scénario

Réflexe commun à tous les scénarios — première heure :

1. **Horodater et noter** ce qui est observé (captures, URLs, logs) — ne rien effacer.
2. **Couper l'exposition** : page maintenance, ou suspendre le projet Supabase (Pause project) si la base est visée.
3. **Révoquer** sessions et secrets du périmètre touché (§6.2).
4. Dérouler le scénario correspondant.
5. **Après reprise** : post-mortem écrit (cause, chronologie, correctifs), mise à jour de ce document.

S1 Front défacé / compte hébergeur compromis

- Révoquer toutes les sessions du compte hébergeur, changer le mot de passe, MFA.
- Vérifier que main sur GitHub est saine (git log, comparer avec la dernière revue) — **le dépôt est la source de vérité**, pas l'hébergeur.
- Redéploier depuis GitHub, ou basculer le DNS vers un hébergeur propre.
- Rotation des tokens de déploiement (intégration GitHub / hébergeur).

RTO attendu : **moins d'1 h**

S2 Fuite de clés (service_role, Pappers, SMTP, anon key)

- Supabase : régénérer les clés API (Dashboard, Settings, API) ; la rotation du secret JWT invalide toutes les sessions utilisateurs — c'est voulu.
- Pappers : révoquer le token sur pappers.fr, en émettre un nouveau. SMTP : révoquer le mot de passe applicatif.
- Reporter les nouvelles valeurs (env. hébergeur + secrets Supabase), redéploier les fonctions, mettre à jour le registre (§6.2).
- Examiner les logs Supabase (Auth + API) sur la période d'exposition : accès anormaux, traiter comme S3.

S3 Données Supabase altérées, supprimées ou exfiltrées

- **Suspendre le projet** (Pause) immédiatement : fige les données et coupe l'accès.
- Évaluer avec les logs : depuis quand, quelles tables, quel volume.
- Restaurer : backup Supabase (Dashboard, Database, Backups) ou dernier dump externalisé — sur un **nouveau projet Supabase** si la compromission du projet lui-même est suspectée, en suivant DEPLOIEMENT.md (schéma, buckets, Edge Functions, secrets, RLS).
- Pointer le front vers le nouveau projet (URL + anon key), rotation complète S2.
- Ressaisir le delta (période entre le dump et l'incident) depuis la main courante du PCA (§3.1.3).
- **Exfiltration de données personnelles : notification CNIL sous 72 h + information des personnes concernées** (cnil.fr, téléservice « Notifier une violation »).

RTO attendu : **4 h ouvrées max** · RPO : **le dernier dump**

S4 Dépôt GitHub compromis

- Révoquer PAT et sessions GitHub du compte touché, mot de passe + MFA.
- Identifier le premier commit malveillant, git revert — ne pas réécrire l'historique : il documente l'attaque.
- **Vérifier si le code malveillant a été déployé** (auto-deploy, cron SQL auto-appliqué) : si oui, dérouler S1 et/ou S3.
- Activer/renforcer la branch protection sur main.

S5 Poste ou messagerie d'un utilisateur compromis

- Désactiver l'utilisateur dans Supabase Auth, ou réinitialiser son mot de passe + révoquer ses sessions.
- Examiner ses actions récentes dans le CRM (logs) ; si écriture suspecte, dérouler S3.
- Poste : antivirus / réinstallation avant de rendre l'accès.

6 · Annexes opérationnelles

6.1 · Sauvegarde quotidienne — prérequis du plan

```
# Cron quotidien sur une machine de confiance :
pg_dump "postgresql://postgres:[MDP]@db.<projet>.supabase.co:5432/postgres" \
  --schema public -F c -f hub_$(date +%F).dump
# Chiffrer puis copier HORS des comptes à risque (stockage distinct
# des identifiants Supabase/GitHub). 30 jours glissants + 12 mensuels.
```

Ne pas oublier le **Storage** (bl-pdfs, contract-templates, delivery-signatures) : export mensuel via l'API Supabase ou `supabase storage cp -r`.

6.2 · Registre des secrets — hors du dépôt

Pour chaque secret : nom, où il est utilisé, où on le révoque, qui a accès. Minimum : clés Supabase (anon, service_role, secret JWT), token Pappers, identifiants SMTP, tokens de déploiement, mots de passe des comptes (Supabase, GitHub, hébergeur, registrar).

6.3 · Contacts d'urgence

Qui	Pour quoi	Canal
Support Supabase	Incident base / auth	Dashboard, rubrique Support
Support hébergeur front	Incident hébergement	Console du compte
Pappers	Révocation token	contact@pappers.fr
CNIL	Violation de données	cnil.fr, téléservice notification
Prestataire réseau / architecte	Serveur local (deb02local)	_____

6.4 · Standard téléphonique

Le texte type, les 4 règles et les escalades du standard sont sur la fiche imprimable dédiée :

Fiche_standard_incident.pdf (1 page, à garder près du poste). Escalades : données personnelles vers **Romain + Dorian** · appel suspect vers **Dorian** · urgence client vers son commercial, sinon **Romain**.

7 · Tests et maintien en condition

Exercice	Fréquence	Contenu
Restauration d'un dump sur un projet Supabase jetable	Trimestrielle	Chronométrer ; vérifier login + une fiche client + un devis PDF
Redéploiement du front sur un hébergeur alternatif	Semestrielle	Depuis GitHub, DNS non basculé, simple vérification
Revue de ce document + registre des secrets	Semestrielle	Rôles, contacts, secrets, écarts
Exercice sur table (dérouler S3 à blanc en équipe)	Annuelle	1 h, Dorian + Guillaume + Laurent (Romain informé du résultat)

Hub Astorya — PCA/PRA v1.3 · source : PCA_PRA.md · fiche standard : Fiche_standard_incident.pdf